NORTHBRIDGE COMMUNITY HEALTH

Name: Sandra Aganyi **Registration number:** C11/26/CGRCE/17565 **Date:** 12 November 2026

Executive position

Recommend an initial $95,000 portfolio: A, B, C and D. This removes the unused supplier workflow, strengthens account access, establishes tested recovery capability and provides managed detection/escalation. The $5,000 balance remains uncommitted. Do not buy insurance as a substitute for controls. Assign a named internal phishing-report owner immediately, even while Option E is deferred.

1 . Evidence and scope

HSE facts (real incident): The HSE says a phishing email was sent to a network user in March 2021 and opening its attachment secretly downloaded malware. The ransomware was triggered in May 2021, encrypting files and blocking access; information was also illegally accessed and copied. HSE states that no ransom was paid. Source: Health Service Executive, “Cyber-attack and HSE response”, last reviewed 1 December 2025: https://www2.hse.ie/services/cyber-attack/what-happened/ (accessed 12 November 2026).

Northbridge assumptions (fictional classroom facts, not HSE facts): Northbridge operates three clinics; an unused supplier workflow is enabled; recovery has not been tested; phishing reports have no escalation owner; essential bookings must continue. The $100,000 budget and all treatment prices are classroom assumptions.

2 . Initial risk register

Scoring: likelihood (L) and impact (I) are each 1–5; score = L × I. Low 1–4; Medium 5–9; High 10–16; Critical 17–25. Ratings are judgement-based classroom assessments. Critical risks cannot be accepted; High risks require board escalation.

ID / risk	Asset; threat; weakness	Business impact	Owner	Initial L×I / rating
R1 Service disruption	**Asset:** Clinic booking and patient-care systems **Threat:** Ransomware encrypts files and makes systems unavailable **Weakness:** Recovery has not been tested; paper bookings support only limited continuity (four hours in change scenario)	Clinics may be unable to manage bookings and coordinate care; patient services delayed	COO / Clinic Operations Director	5 × 5 = **25 Critical**
R2 Sensitive-data loss	**Asset:** Patient records and personal/medical information **Threat:** Ransomware operator steals or discloses sensitive data **Weakness:** Phishing can provide an entry point; access-control effectiveness has not been evidenced in the case facts	Confidentiality breach, patient harm, regulatory action, legal costs and loss of trust	Data Protection Officer / IT Security Lead	4 × 5 = **20 Critical**
R3 Unnecessary supplier exposure	**Asset:** Supplier workflow and connected clinic systems **Threat:** Compromise of a supplier account or connected workflow is used to enter the environment **Weakness:** Unused supplier workflow remains enabled	Unauthorised access, lateral movement, data exposure or operational disruption	Procurement Lead / IT Service Owner	4 × 4 = **16 High**
R4 Delayed detection	**Asset:** Email, endpoint and network environment **Threat:** Phishing-led malware activity progresses to ransomware before containment **Weakness:** Phishing reports have no named escalation owner	Longer attacker dwell time, wider encryption/data theft and slower containment	IT Security Lead / Incident Response Owner	4 × 4 = **16 High**

Rating rationale

R1 is Critical (5×5): loss of booking and clinic systems could immediately interrupt essential care, and recovery is untested. R2 is Critical (4×5): health information is highly sensitive and disclosure could cause serious patient, legal and trust impacts; likelihood is high because phishing is a credible route and access-control effectiveness is unverified. R3 is High (4×4): the enabled but unused workflow is an avoidable supplier entry path, with potentially broad access consequences. R4 is High (4×4): no reporting escalation owner can delay triage and containment, increasing the chance and scale of harm

3 . Initial treatment portfolio and alternatives

Option	Decision / treatment	Cost	Risk rationale
A	Select – retire unused supplier workflow (avoidance)	$5,000	Removes unnecessary exposure at low cost; verify account, integration and permission removal.
B	Select – MFA and access review (mitigation)	$25,000	Reduces account takeover and excessive access risk.
C	Select – protected backups, restoration tests and recovery plan (mitigation)	$30,000	Directly addresses untested recovery and essential booking continuity.
D	Select – managed detection and escalation (mitigation)	$35,000	Provides monitoring and a defined escalation capability; Northbridge retains incident command and accountability.
	Total selected	**$95,000**	**Remaining: $5,000**

Alternatives and risk acceptance

Option E ($10,000) is deferred initially; Northbridge must still appoint an internal phishing-report owner at no additional cost and document a reporting route. Option F ($40,000) is deferred because the full portfolio would exceed the budget; segmentation remains a board-visible residual exposure. Option G ($20,000 premium) is not selected as a control portfolio item: insurance transfers only defined financial loss and does not prevent disruption, protect patients or remove accountability. No High or Critical risk is accepted. A short, documented administrative tolerance for the deferred awareness programme may be permitted only until 30 November 2026, owned by the IT Security Lead, reviewed weekly and approved by the simulated Board Risk Committee; it does not authorise acceptance of the underlying High/Critical risks.

4 . Retained financial exposure – Option G illustration

Covered loss	Insurer payment calculation	Insurer pays	Retained loss	Plus $20,000 premium: first-year outlay
$180,000	min(max(180,000−25,000,0),250,000)	$155,000	$25,000	$45,000
$400,000	min(max(400,000−25,000,0),250,000)	$250,000	$150,000	$170,000

If a claim is excluded, insurer payment is $0: Northbridge bears the full $180,000 or $400,000 loss, plus the $20,000 premium already paid (total outlay $200,000 or $420,000). Actual coverage depends on policy wording; these are fictional terms only.

5 . Change scenario – revised decision

New facts: the restoration test fails; paper bookings are viable for only four hours; Option B rises from $25,000 to $35,000. Revise to A + C + D + E = $80,000, leaving $20,000. Defer B at its revised $35,000 price. Keep C because recovery is essential, but mark it **not yet effective**: a failed test is evidence of a control gap, not successful mitigation. D provides detection/escalation and E creates an owned reporting process. The four-hour paper booking limit makes continuity urgent; the COO must escalate the Critical service risk to the board immediately and arrange an interim clinic downtime procedure and repeat restore test. The board must also escalate the deferred MFA/access-control exposure and approve the revised risk position.

Revised risk ownership: R1 – COO / Clinic Operations Director (Critical 5×5=25 until successful restore and continuity test); R2 – DPO / IT Security Lead (Critical 4×5=20 while MFA is deferred); R3 – Procurement Lead / IT Service Owner (Low 1×4=4 only after workflow retirement is verified); R4 – IT Security Lead / Incident Response Owner (Medium 2×4=8 only after D and E escalation tests pass). Any High/Critical residual requires board escalation; no such risk is silently accepted.

6 . 30-day treatment plan and residual risk

Action	Owner	Cost	Target	Effectiveness test / evidence
Disable and retire unused supplier workflow; remove related accounts, tokens and permissions	IT Service Owner + Procurement	$5,000 (A)	Day 5	Configuration and access review confirms workflow disabled and no active credentials/integrations remain.
Implement protected backups; investigate failed restore; remediate and repeat restoration test; approve recovery runbook	IT Operations Lead + COO	$30,000 (C)	Day 20	Successful restore of representative clinic systems; record recovery time, data integrity and booking workflow; demonstrate recovery within approved service target.
Activate managed detection, incident escalation contacts and tabletop exercise	IT Security Lead + service provider	$35,000 (D)	Day 15	Simulated alert reaches named Northbridge incident owner within agreed SLA; evidence of triage, escalation and decision log.
Deliver targeted phishing awareness; publish report route and assign named escalation owner	HR + IT Security Lead	$10,000 (E)	Day 12	Staff complete training; test message/reporting exercise reaches owner and is triaged within agreed target.
Create clinic paper-booking downtime procedure and rehearse four-hour limit; escalate MFA funding decision	COO + Clinic Managers; Board Risk Committee	$0 incremental in case budget	Day 7	Each clinic completes a timed exercise; record booking reconciliation and safe handover. Board records decision on B and residual risk.

Proposed residual ratings

The revised residual ratings are R1 5×5=25 Critical because the restore test failed and the paper fallback lasts only four hours; R2 4×5=20 Critical because MFA/access review is deferred; R3 1×4=4 Low after verified retirement of the workflow; R4 2×4=8 Medium only after managed detection and the reporting process are tested. These are targets/assumptions, not proof that controls work. Until effectiveness evidence exists, retain the initial score for the affected risk. The board must not accept Critical risks; High/Critical risks require escalation.

7 . Board memo

To: Northbridge Board Risk Committee
Subject: Approval of ransomware risk treatment portfolio

I request approval of the revised first-year treatment portfolio of **$80,000**: retire the unused supplier workflow (A, $5,000), protected backups and recovery planning (C, $30,000), managed detection and escalation (D, $35,000), and targeted awareness/reporting (E, $10,000). This leaves $20,000

of the $100,000 budget uncommitted. Option B has increased to $35,000 and is deferred; this creates a significant access-control gap requiring explicit board oversight.

The restoration test has failed, and paper bookings can sustain operations for only four hours. The COO should treat service continuity as the immediate priority: maintain safe clinic operations, rehearse the downtime process, reconcile paper bookings and repeat restoration testing after remediation. The failed test means backups/recovery cannot yet be treated as effective. The COO must own the Critical service-disruption risk and report progress to the Board Risk Committee.

The board should approve the portfolio, require a successful restore and clinic continuity exercise within 30 days, and decide how and when to fund MFA/access review. Sensitive-data exposure remains Critical while MFA is deferred. Supplier exposure may fall to Low only after verified retirement; detection risk may fall to Medium only after escalation tests pass. No Critical risk is proposed for acceptance. Outsourced monitoring and any insurance do not transfer Northbridge's accountability for patient care, privacy or incident decisions.

Source: Health Service Executive, "Cyber-attack and HSE response", https://www2.hse.ie/services/cyber-attack/what-happened/ (accessed 12 November 2026). All Northbridge facts, costs, scores and insurance terms are fictional classroom assumptions. Enter your name and registration number before submission.